

Verificación de Antioquia Natural

Proyectos: Antioquia Natural

Documentos revisados

- Levantamiento de Requisitos de Software y Propuesta Técnica - Frente a la plantilla FO-M7-P8-020.
- Propuesta Técnica y Financiera de Desarrollo de Software / Ajustes Técnicos v2 - Frente a la plantilla FO-M7-P8-021.
- Documento Integral de Desarrollo Técnico de la Aplicación - Frente a la plantilla FO-M7-P8-023.
- Manual de Lineamientos de Seguridad de la Información de la Gobernación de Antioquia - usado como fuente de contraste para los hallazgos 4.3 y 4.4 de este documento.

Criterio de estado (verificación de cierre)

-  Resuelta completamente - La observación fue atendida en su totalidad en la versión FINAL.
-  Parcialmente resuelta - Existe una corrección, pero queda un remanente del problema original.
-  No resuelta - La versión FINAL no atiende la observación.

Criterio de severidad (hallazgos nuevos)

- [Crítico] - Incumplimiento de un requisito de control documental, ausencia de una sección obligatoria, o contradicción técnica de fondo entre documentos.
- [Moderado] - Sección presente pero incompleta, contenido fuera del formato exigido, o requerimiento sin trazabilidad técnica clara.
- [Menor] - Ajuste de forma, error de redacción/referencia cruzada, o alcance opcional según la plantilla.

1. Verificación de Cierre - Levantamiento de Requisitos de Software

Plantilla de referencia: Levantamiento de Requisitos de Software (Código FO-M7-P8-020).

Observación original	Estado	Comentario
No cuenta con la portada sugerida en la plantilla.	 Resuelta	La FINAL incluye portada con logo, código FO-M7-P8-020, versión 01, fecha de aprobación y autores.
El documento pasa directo de la portada al numeral 1, sin índice de contenidos.	 Parcial	Existe una sección "Contenido" (numerales 1–6), pero el documento continúa con los numerales 7 a 10 (soporte, garantía, derechos morales, cumplimiento de lineamientos), que no aparecen indexados.
El documento no cuenta con la fuente de la letra, el tamaño, el diseño de las tablas.	 Resuelta*	Visualmente consistente con el esquema institucional. *No fue posible verificar la tipografía exacta a partir del PDF.

Cumple correctamente: Estructura de numerales, columnas de las tablas de Requerimientos Funcionales y No Funcionales, diccionario de acrónimos y Notas Finales (soporte, garantía, derechos morales, cumplimiento de lineamientos).

2. Verificación de Cierre - Propuesta Técnica y Financiera / Ajustes Técnicos v2

Plantilla de referencia: Propuesta Técnica y Financiera de Desarrollo de Software (Código FO-M7-P8-021).

Observación original	Estado	Comentario
No cuenta con la portada sugerida en la plantilla.	☒ Resuelta	Portada con código FO-M7-P8-021 incluida.
El documento pasa directo de la portada al Contexto y alcance, sin índice de contenidos.	☒ Resuelta	Tabla de contenido completa (numerales 1 a 10), correspondiente con el cuerpo del documento.
No existe la tabla formal de Control de Ajustes (numeral 9).	☒ Resuelta	Tabla Versión/Fecha/Descripción del Cambio/Responsable, con 4 entradas (1.0 a 2.2).
Diccionario de Definiciones y Acrónimos no incluido.	☒ Resuelta	Tabla con 11 términos (SAST, MFA, OIDC, OAuth 2.0, PKCE, JWT, MSAL, TTL, SLA, CVE, OWASP).
Compromisos (numeral 8) no aborda propiedad intelectual, confidencialidad ni cumplimiento normativo.	☒ Resuelta	Incluye los tres puntos exigidos, con referencia explícita a la Ley 1581 (Habeas Data) en relación con el Ajuste 1 (Entra ID).
No hay bloque formal de firma Cliente / Proveedor (numeral 10).	☒ Resuelta	Bloques "Por el Cliente" y "Por el Proveedor de Desarrollo" presentes.
Cronograma usa columnas distintas a la plantilla y sin fechas concretas.	☒ Resuelta	Se agregó columna "Entregable".
El documento no cuenta con la fuente de la letra, el tamaño, el diseño de las tablas.	☒ Resuelta*	Visualmente consistente.

Cumple correctamente: El stack tecnológico actualizado es más completo de lo exigido, y cada ajuste sigue una estructura consistente (situación actual → propuesta → justificación → especificación técnica).

3. Verificación de Cierre - Documento Integral de Desarrollo

Plantilla de referencia: Documento Integral de Desarrollo Técnico de la Aplicación (Código FO-M7-P8-023).

Observación original	Estado	Comentario
No cuenta con la portada sugerida en la plantilla.	☒ Resuelta	Portada con código FO-M7-P8-023 incluida.
El documento pasa directo de la portada al numeral 1, sin índice de contenidos.	☒ Resuelta	Tabla de contenido detallada (numerales 1–13 + Anexos) con paginación.
No hay un solo diagrama (arquitectura, infraestructura, DER).	☒ Resuelta	Incluye Figuras 1, 2, 2a, 2b (arquitectura general/detallada y secuencia), 3 (infraestructura) y 4 (DER). Excede lo exigido.
No se menciona metodología, gestión de proyecto, control de versiones ni CI/CD.	☒ Resuelta	Numeral 5 completo, con tabla de pipeline de 7 pasos.
Manual Técnico sin procedimiento de rollback.	☒ Resuelta	Numeral 10.5, 7 pasos detallados.
No hay bloque formal de firmas (numeral 12).	☒ Resuelta	Numeral 13, bloques para Dirección TIC, líder funcional y desarrollo.

Observación original	Estado	Comentario
No hay diagramas de flujo para procesos clave.	☒ Resuelta	Numeral 11.1, Figura 5 (flujo de publicación mensual JPL/Guarda Cuencas).
Tabla de tecnologías incompleta y sin justificación.	☒ Resuelta	Tabla 4.1 con Código/Tecnología/Versión/Descripción/Utilidad; 4.2 justifica las decisiones clave.
No se describen entornos Dev/QA/Prod ni escalabilidad.	☒ Resuelta	Numerales 6.2, 6.3 y 6.5 con buen nivel de detalle.
Diccionario de datos no mencionado como entregable aparte.	☒ Resuelta	Numeral 7.6 referencia el Excel versionado; listado en Anexos. No se pudo verificar su contenido (no adjunto).
No hay referencia a políticas de seguridad institucionales.	☒ Resuelta	Numeral 8.4 referencia la Guía de Arquitectura y Buenas Prácticas, sección 9.
Se reportan resultados de pruebas pero no la estrategia ni el proceso.	☒ Resuelta	Numerales 9.1 y 9.5 agregados.
No existe un Roadmap Técnico consolidado (opcional).	☒ No resuelta	El numeral 12 quedó con el texto instructivo de la plantilla sin diligenciar ("Cómo Llenar: Describir las futuras mejoras...").
El documento no cuenta con la fuente de la letra, el tamaño, el diseño de las tablas.	☒ Resuelta	Visualmente consistente.

Cumple correctamente y de forma sobresaliente: La sección de Seguridad (autenticación, licencias de dependencias, cifrado) y la documentación del modelo de datos (colecciones activas vs. definidas sin uso).

4. Hallazgos Nuevos (Auditoría de Consistencia entre Documentos FINAL)

Adicional a la verificación de cierre, la auditoría integral de la versión FINAL de los tres documentos identificó los siguientes hallazgos, no contemplados en la revisión anterior.

[Crítico]

Documento(s)	Hallazgo	Severidad	Por qué importa
PTF (2.2) vs. DI (3.1, 7.1) vs. LRS (3.2)	La PTF justifica Redis diciendo que cachea el catálogo de especies "en vez de una consulta directa a MongoDB (60-120 ms)". El DI y el LRS afirman, de forma consistente entre sí, que el catálogo de especies nunca pasa por MongoDB ni por la API: se sirve como JSON estático desde el frontend.	[Crítico]	Son afirmaciones mutuamente excluyentes sobre la misma arquitectura de caché. Un revisor técnico no puede aprobar el Ajuste 2 sin que esto se aclare.
DI (numeral 8.1) vs. Manual de Lineamientos de Seguridad de la	El panel de administración usa "una sola contraseña compartida entre los curadores del panel (Jóvenes pa' Lante y Guarda Cuencas)", sin cuentas individuales. El Manual de Lineamientos prohíbe	[Crítico]	No es una simple limitación técnica temporal, como la presenta el DI: es un incumplimiento directo y documentado de una

Documento(s)	Hallazgo	Severidad	Por qué importa
Información de la Gobernación	expresamente las "cuentas de usuario genéricas" salvo excepción formal aprobada mediante el formato FO-M7-P8-016, que no está referenciado en ningún documento. Tampoco hay integración con el Gestor de Contraseñas / Gestor de Acceso de la Entidad, ni reCAPTCHA en el login del panel, ambos exigidos por el mismo manual.		política de seguridad institucional obligatoria. Además, impide aplicar Acceso según Funciones, Mínimo Privilegio (PAM) y Revisión Mensual de Privilegios, exigidos en el mismo manual, porque no existen usuarios individuales que auditar.
PTF (Ajuste 3) vs. DI (numeral 5.4)	Los documentos proponen construir un pipeline de CI/CD propio en Azure DevOps con ESLint-security + Semgrep, la Gobernación ya cuenta con un pipeline de CI institucional al cual el proyecto debería integrarse en su lugar.	[Crítico]	Se debería usar el pipeline ya existente la fase CI de la institución lugar de construir uno nuevo, el cual debe añadir es todo el CD para el despliegue de la aplicación.
LRS (3.5) + PTF (3.2) + DI (numeral 6 completo) vs. documentación de arquitectura y seguridad de la Gobernación (buenas prácticas de contenerización y hardening)	Ninguno de los tres documentos menciona Docker, Kubernetes ni ninguna forma de containerización. El despliegue documentado de forma consistente en los tres es instalación nativa sobre el sistema operativo: backend gestionado por PM2 directo sobre Ubuntu 24.04 LTS, y Nginx como proxy inverso nativo - sin Dockerfile, sin imágenes, sin paso de build/escaneo de imagen en el pipeline de CI/CD.	[Crítico]	La documentación institucional exige containerización con 6 controles específicos de hardening). Al no existir ningún contenedor en la arquitectura documentada, ninguno de esos 6 controles es aplicable ni evaluable hoy. El gap se propaga al Manual Técnico (despliegue y rollback asumen git checkout + pm2 restart, no build/run de imágenes), al pipeline de CI/CD (sin build ni escaneo de imagen) y al Diagrama de Infraestructura (Figura 3), que tendría que representar contenedores/orquestador.

Detalle de los 6 controles de hardening de contenedores exigidos por la documentación institucional, contrastados contra el estado actual de los tres documentos:

Control exigido	¿Aplicable hoy?	Observación
Inyección de secretos (no hardcodear credenciales en la imagen)	No aplica - no hay imagen Docker	A nivel de código, el DI (8.3) sí declara que las credenciales se leen de variables de entorno (ADMIN_PASSWORD_HASH, MONGODB_URI_COM, SESSION_SECRET), lo cual sería trasladable a un futuro Dockerfile, pero hoy no existe el artefacto de imagen al que aplicarle el control.
.dockerignore (aislamiento de archivos innecesarios)	No mencionado	No puede existir sin un Dockerfile / proceso de build de imagen, que tampoco están documentados.

Control exigido	¿Aplicable hoy?	Observación
Usuario non-root en el contenedor (mínimo privilegio)	No mencionado	No hay contenedor al que aplicarle esta configuración.
Multi-stage builds	No mencionado	Ídem - no hay Dockerfile documentado.
HEALTHCHECK de contenedor	Cubierto solo parcialmente, por otra vía	El DI tiene un endpoint GET /api/health (10.6) que valida MongoDB y Redis, y PM2 reinicia el proceso ante caída (6.5): es un healthcheck a nivel de aplicación/proceso, no la instrucción HEALTHCHECK a nivel de contenedor que un orquestador necesitaría.
Análisis de vulnerabilidades de imágenes en el pipeline de CI/CD	No aplica - no hay imágenes que escanear	El pipeline del DI (5.4) sí ejecuta npm audit, ESLint-security y Semgrep, pero eso analiza código y dependencias npm, no imágenes de contenedor. No hay paso de build de imagen ni de escaneo (tipo Trivy/Grype o el escáner de Azure DevOps/ACR) en ningún punto documentado.

[Moderado]

Documento(s)	Hallazgo	Severidad	Por qué importa
DI	El numeral 12 "Roadmap Técnico (Opcional)" quedó con el texto instructivo de la plantilla sin diligenciar, pese a que el propio documento ya menciona, dispersos, varios ítems de roadmap real (migración a Entra ID, migración de Biodiversidad a MongoDB).	[Moderado]	Va en contra del criterio de "no dejar textos de ejemplo de la plantilla"; además es una oportunidad perdida de consolidar información que ya existe en el documento.
LRS vs. DI	RQP09 ("API REST de consulta" pública de especies/familias/grupos/subregiones) no tiene soporte técnico verificable: el DI afirma que la API REST es consumida "únicamente por el panel de administración".	[Moderado]	No queda evidencia de un endpoint público de consulta de biodiversidad, que es justamente lo que exige RQP09.
DI - Figura 1 (Arquitectura general) vs. numerales 6.3/6.4 del DI y Ajuste 2 de la PTF	El diagrama agrupa MongoDB y Redis dentro de una misma caja "Persistencia", sin distinguir su ubicación real. El texto dice que Redis corre "en modo standalone, en el mismo servidor Ubuntu... sin costo de infraestructura adicional", mientras que MongoDB es "el único componente de producción que depende de un proveedor externo".	[Moderado]	Alguien que solo revise el diagrama (sin leer el texto) concluiría que Redis también es un servicio externo, cuando en realidad corre en el mismo servidor que el backend y el frontend. El diagrama no separa qué recae en infraestructura propia de la Gobernación y qué en un proveedor externo.

[Menor]

Documento(s)	Hallazgo	Severidad	Por qué importa
LRS	El índice de contenido lista solo hasta el numeral 6; los numerales 7 a 10 (soporte, garantía, derechos morales, cumplimiento) no están indexados.	[Menor]	Reintroduce parcialmente el problema original de "falta de índice" en el tramo final del documento.
DI	Error de referencia cruzada: la introducción del numeral 9 ("Pruebas y Testing") cita subnumerales "8.1" a "8.5" en vez de "9.1" a "9.5".	[Menor]	Error de redacción / referencia cruzada.
DI	Error tipográfico en la introducción del numeral 5: "control de versiones 54.3)" en vez de "(5.3)".	[Menor]	Error de redacción.
DI - Figura 1 (Arquitectura general) vs. Figura 3 (Infraestructura)	El middleware de autenticación se muestra como "adminAuth" (session + bcrypt, el mecanismo actual) sin ninguna anotación de que ahí se integrará Microsoft Entra ID a futuro, a diferencia de la Figura 3, que sí usa anotaciones explícitas para marcar pendientes de TI Gobernación.	[Menor]	No es un error de fondo (Entra ID en efecto no está implementado hoy, por lo que es correcto que no aparezca como "actual"), pero la falta de anotación deja al diagrama sin comunicar que existe un diseño objetivo distinto al estado actual, información que el documento sí tiene pero no propaga de forma consistente a todos sus diagramas.

5. Recomendación Transversal (aplica a varios documentos)

Varios de los hallazgos de este documento - Entra ID presentado sin distinción de "actual" vs. "pendiente" en la tabla de Stack Tecnológico de la PTF y en la Figura 1 del DI, el Roadmap Técnico vacío del DI (numeral 12), y la falta de anotación de Entra ID en la Figura 1 - comparten una misma causa raíz: la información sobre qué está implementado hoy y qué depende de un insumo externo de TI Gobernación existe en el documento (el numeral 1 "Estado del documento" y el numeral 8.1 del DI la comunican con claridad), pero no se propaga de forma uniforme a todas las secciones, tablas y diagramas relacionados.

Se recomienda adoptar una convención uniforme de "Estado: Implementado / Pendiente de insumo TI" y aplicarla de forma consistente en: (a) la tabla de Stack Tecnológico de la PTF (numeral 2.2), agregando una columna o nota de estado por cada tecnología en vez de listar Entra ID igual que Node.js o MongoDB; (b) los diagramas de arquitectura del DI, en particular la Figura 1; y (c) reforzando el numeral 1 "Estado del documento" del DI como el punto único de verdad al que las demás secciones remitan, en vez de que cada una decida por su cuenta cómo (o si) comunicar lo pendiente.